

Corrected AI Risk Register

and STRIDE Worksheet

Five finalised risk register entries and eight finalised STRIDE threats, corrected under human review

Field	Value
System under review	Contoso Customer Onboarding Assistant — GenAI conversational system for retail banking customer onboarding (identity verification, product selection, account setup)
Document purpose	The finalised risk register and threat model. Supersedes the raw drafts recorded in Audit Trail Record.docx. Every difference between the two is stated in the Human-Review Annotation column.
Frameworks	NIST AI Risk Management Framework (AI RMF 1.0) — risk register. STRIDE — threat model.
Reviewer	AI Governance Analyst
Review date	25 August 2026
Status	Draft for Chief Risk Officer review. Not approved for production release.
Companion document	Audit Trail Record.docx — CTCV prompts and raw, unedited GenAI outputs.

Scope note

The scenario brief supplied with this engagement (v1.2-Pilot) documents an HR employee-onboarding assistant. The system assessed here is the retail banking customer onboarding assistant defined in the Chief Risk Officer's tasking. The brief, the inherited register entries R-01 to R-04, and the inherited STRIDE rows have been treated as a reference model. Where an inherited control does not apply to this system, the annotation says so and the row is superseded rather than amended.

Entries R-05 to R-09 extend the inherited register, which retains R-01 to R-04. Threats T-01 to T-08 replace the inherited worksheet in full, because that worksheet modelled only the retrieval layer and the inference endpoint.

Pre-submission environment check

Recorded before any prompt was submitted to the Guided Scenario Simulation environment.

Check	Result
Microsoft Purview DLP indicator	Confirmed active before any prompt was submitted.
Azure AI Content Safety Prompt Shields	Confirmed active before any prompt was submitted.
Input discipline	No content carrying a Confidential or Highly Confidential label was pasted into any prompt. Data classes were referenced by class name only — for example "government-issued ID number" — with no specimen values, no synthetic customer records, and no excerpts from labelled source material.
Prompts submitted	Two, both CTCV-structured. Full text recorded in Audit Trail Record.docx, Section 1.
Raw outputs captured	Yes, before any edit. Recorded in Audit Trail Record.docx, Section 2.
Basis of this document	Those raw outputs, corrected under human review. Every correction is recorded in the Human-Review Annotation column of the entry it affects.

Summary of corrections applied

Every correction below is stated in full in the annotation column of the entry it affects. An entry may appear under more than one correction type.

Correction type	Entries affected	Why
Numeric scores replaced with stated reasoning	R-05, R-06, R-07, R-08, R-09	Required by the submission structure. Also resolves the underived-residual defect carried by the inherited register.
Unverifiable assertion reframed as an unconfirmed state	R-05, R-07	The draft asserted vendor and architecture behaviour it had itself flagged as assumption.
Scope broadened after review	R-06, R-08, T-03	The draft addressed one instance of a failure mode that has several.
Unevidenced "Mitigated" status withdrawn	T-04, T-06, T-07	Status asserted in the inherited worksheet with no verification method or evidence named.
Inherited control found inapplicable	T-01, T-06	Control was written for the reference HR system and does not exist in this architecture.
Control demoted or reprioritised	R-07, R-09, T-03, T-08	A probabilistic or detective control was standing where a deterministic or preventive one is required.
Cross-artifact conflict recorded	R-06, R-08, T-04, T-05	Register, worksheet and Output Evaluation Checklist disagree; recorded rather than reconciled silently.
Gap recorded rather than closed	R-09, T-07	No defensible value or control could be stated; an estimate was deliberately not substituted.

Amendments required outside this document

Human review found conflicts that cannot be resolved inside the register or the worksheet. Each requires a change to another artifact before the assistant enters production review.

Artifact and clause	Finding	Raised at
Output Evaluation Checklist — PII sanitisation rule	Section 5. As written it strips the data classes the assistant exists to collect. Must be restated as directional: strip on egress, retain in-session.	T-05
Output Evaluation Checklist — 0.75 similarity threshold	Section 3. Calibrated against a single configuration; not valid after a model version, filter threshold, or corpus change.	R-08
Output Evaluation Checklist — logging fields	Section 4 requires Context_Docs_Retrieved per request; the inherited logging design does not capture it.	T-04
Retention policy — ceiling versus floor	A 90-day ceiling is stated while banking record-keeping obligations impose floors. One of the two is currently breached.	R-06, T-04
Data Classification Standard — label allocation	The two sensitivity labels are named but the six data classes are not allocated between them. Several controls depend on the allocation.	R-05

Open verification actions

Facts that human review could not establish. No estimate has been substituted for any of them, and no entry in this document should be treated as closed while its action remains outstanding.

- Confirm the content-logging exemption status for this deployment against current vendor documentation. (R-05)
- Obtain the approved allocation of the six data classes to the Confidential and Highly Confidential labels. (R-05)
- Establish the regulatory retention floor and reconcile it with the 90-day ceiling. (R-06, T-04)

- Obtain the interface contract for the account-opening integration and confirm whether the assistant holds a write capability. (R-07, T-08)
- Confirm whether the deployment pins a model version, and whether a regression evaluation suite exists. (R-08)
- Identify the identity-verification component and obtain disaggregated false-accept and false-reject performance. (R-09, T-01)
- Confirm whether the orchestration service authenticates by managed identity or by key. (T-02)
- Obtain the application and platform logging configuration, including what payload content is captured by default. (T-05)
- Obtain the session and cache design for conversation state. (T-06)
- Confirm the risk owner roles named in this register against Contoso's RACI for AI systems. (R-05 to R-09)

Part 1 — AI Risk Register

Five finalised entries, R-05 to R-09, spanning the data, model and usage domains. Likelihood and impact are stated as reasoning rather than as scores, so that each rating can be challenged on its basis rather than accepted as a number.

Entry #	NIST AI RMF Category	Risk Description	Likelihood Reasoning	Impact Reasoning	Human-Review Annotation
R-05	MANAGE — Data Protection & Boundary Integrity	Prompt and completion content containing government-issued ID numbers and declared annual income is retained or reviewed on the platform side of the inference service, placing Highly Confidential data outside Contoso's controlled processing path even though inference itself remains in-tenant. The deployment's content-logging exemption status is unconfirmed.	Rated medium-high. The exposure is configuration-dependent rather than probabilistic: it is either present or absent according to whether a content-logging exemption has been approved for this deployment. No one has confirmed which, and the conservative position is to assume it is not yet in place. The rating reflects an unverified configuration, not observed incident data.	Rated high. Government-issued ID number and declared annual income are the two data classes provisionally labelled Highly Confidential. Retention outside the controlled path breaches the stated constraint that all inference remain within the tenant boundary. The breach is of the control itself and does not require the data to be misused before it becomes reportable.	CORRECTION — the draft asserted a specific vendor retention behaviour as established fact while simultaneously disclosing it as an unverified assumption (Audit Trail Record, Output 1, assumption 2). Restated as an unconfirmed configuration state, so the entry remains valid whichever way verification lands. BASIS — the tenant-boundary constraint is stated in the CRO tasking; the vendor behaviour is not. ACTION — confirm exemption status against current vendor documentation before production review. Numeric scores (3x5=15 inherent, 2x5=10 residual) removed: the residual could not be justified without post-control measurement.
R-06	GOVERN — Data Lifecycle & Retention	Session PII persists past the 90-day boundary in derived stores — vector embeddings, conversation cache, Content Safety logs, telemetry and backups — because deletion is implemented only against the primary transcript store. The same boundary may simultaneously sit below the retention floor imposed by banking record-keeping obligations.	Rated high, on architecture rather than observation. The design creates at least five derived copies of session content, and deletion pipelines conventionally target the primary store alone. No deletion-test evidence exists for this system. The second limb — under-retention — is not probabilistic at all: it holds until the ceiling and floor are reconciled.	Rated high, and two-sided. Over-retention breaches the stated policy for Confidential and Highly Confidential classes. Under-retention removes the evidence needed to answer a customer dispute or a regulatory request. Because the tasking sets a 90-day ceiling while citing regulations that impose floors, one of the two failures is currently guaranteed.	CORRECTION — the draft treated 90 days as a straightforward ceiling; human review added the ceiling-versus-floor conflict, which the draft raised only as missing information rather than as part of the risk. SECOND CORRECTION — the draft proposed an assessment to determine whether embeddings should be treated as personal data. Review reverses the default: embeddings derived from PII are treated as personal data unless demonstrated otherwise. NOTE — no equivalent risk exists in inherited entries R-01 to R-04, because the reference HR system ingested no PII at all.
R-07	MANAGE — Adversarial Manipulation & Excessive Agency	Indirect prompt injection embedded in a retrieved product-disclosure document causes the assistant to invoke the downstream account-opening interface and complete account setup without a passed identity-verification result, or to tell an applicant that setup has completed when it has not.	Rated medium. Injection through retrieved content is an established and repeatedly demonstrated technique, and the retrieval corpus is a plausible insertion point. Held below high because it requires an attacker to first place content in the corpus, which is itself a controlled path. No adversarial testing has been performed against this system.	Rated high. If the assistant holds a write capability against the account-opening interface, the outcome is an account created without identity verification — a control failure with reporting consequences, not a service defect. Without that capability, impact falls to a misled applicant. The write capability is unconfirmed and is the single fact that determines this rating.	CORRECTION — the draft rated impact on the assumption that a real write capability exists (Output 1, assumption 3). Restated so the entry holds at both levels and names the determining fact. SECOND CORRECTION — the draft listed Content Safety prompt shields alongside deterministic enforcement as mitigation. Review demotes prompt shields to a supporting detective control: a probabilistic filter must not be the primary control for a state-changing action. ACTION — obtain the interface contract for the account-opening integration.

Entry #	NIST AI RMF Category	Risk Description	Likelihood Reasoning	Impact Reasoning	Human-Review Annotation
R-08	MEASURE — Model Reliability & Grounding	System behaviour changes without any change to application code — through a model version update, a Content Safety threshold change, or an update to the retrieval corpus — degrading grounding or refusal behaviour on product-eligibility questions after the evaluation baseline was set, with no revalidation triggered.	Rated high. Three independent change surfaces sit outside the application release cycle, and at least one moves on a vendor's schedule rather than Contoso's. Whether the deployment currently pins a model version is unknown. The rating reflects the number of unmanaged change surfaces, not measured drift, of which there is none for this system.	Rated medium. Degradation surfaces as incorrect product terms or inappropriate refusals rather than as data loss, and is recoverable once detected. Held below high only because a regression suite makes it detectable; absent that suite, detection depends on customer complaint, which would raise impact to high.	CORRECTION — the draft scoped this to model version updates alone. Human review broadened it to all three surfaces that alter behaviour without a code change, since the revalidation gap is identical for each. SECOND CORRECTION — the draft's likelihood of 4 was unsupported; replaced with reasoning that names what the rating rests on. CROSS-REFERENCE — the 0.75 similarity threshold in the Output Evaluation Checklist is calibrated against one configuration and is not valid after any of these changes. The checklist requires a corresponding amendment.
R-09	MAP — Fairness, Transparency & Human Oversight	Applicants rejected by automated identity verification are excluded from account opening with no documented human review path and no reason recorded at the point of rejection. Because no reason is captured, any difference in false-reject rates across applicant groups is undetectable, and any contribution the assistant makes to a denial cannot be explained.	Not rated. The oversight gap — absence of a documented review path and of reason capture — is a present-state finding rather than a probability, and resolves to true or false on inspection. The fairness limb cannot be rated at all: no disaggregated performance data exists for the verification component, and none can be produced until reason capture is in place.	Rated high, qualitatively. Exclusion from account opening is a consumer-facing outcome, and an inability to state the reason for a denial is a compliance exposure independent of whether any disparity is later found. Stated qualitatively because no measurement currently supports a numeric rating.	CORRECTION — the draft framed this as a fairness-measurement risk and left the residual underived, rating its own confidence low (Output 1, R-09). Review accepts the gap but reorders the entry: the oversight failure is the controllable element and the precondition for any fairness measurement, so it now leads the risk statement. The unrated likelihood is deliberate and must not be filled with an estimate. ACTION — obtain the verification component's identity and performance data. ROLE — owner named as Fair Lending Officer in the draft; existence unconfirmed against Contoso's RACI.

Part 2 — STRIDE Worksheet

Eight finalised threats scoped to the inference endpoint and its immediate data path, covering all six STRIDE categories. Components are cited as C-1 to C-10 and trust boundaries as TB-1 to TB-5, per the agreed scope.

Threat #	STRIDE Category	Threat Description	Affected Component	Mitigation Approach	Human-Review Annotation
T-01	Spoofing	An attacker completes onboarding using a stolen identity document and matching static PII, impersonating a real person. There is no prior authenticated relationship against which the applicant can be checked, so the system's only evidence of identity is the data the attacker supplies.	C-1 Client channel (unauthenticated onboarding session). Boundary TB-1, unauthenticated internet to orchestration.	Document liveness and biometric match performed at the client channel; device and network signal binding; velocity and reuse checks across sessions. All proposed — no verification control is named in the architecture supplied. Corporate SSO is not an available control here.	CORRECTION — the inherited worksheet mitigated Spoofing with corporate SAML SSO and JWT expiry and marked it Mitigated. That control does not exist for this system: onboarding applicants are unauthenticated members of the public. The inherited row is superseded, not amended. SECOND CORRECTION — the draft returned status 'Open / In Progress'; no remediation is known to be underway, so this is recorded as open with no confirmed control. Links to register entry R-09.
T-02	Spoofing	A workload credential or API key for the inference endpoint is captured and replayed from outside the orchestration service, allowing an attacker to submit inference requests that appear to originate from the assistant and to consume the tenant's quota under Contoso's identity.	C-10 Secrets and workload identity plane. Boundary TB-2, orchestration to inference endpoint.	Managed workload identity in place of API keys; private endpoint and network isolation on the inference endpoint; scheduled key rotation where keys remain in use; egress restriction from the orchestration service.	SCOPE NARROWED — the draft stated this threat unconditionally. Review confirms it applies only where key-based authentication is in use; if managed identity is already configured, the threat is largely closed and this row should be downgraded rather than remediated. The current credential mechanism was not supplied. ACTION — confirm the authentication method before assigning remediation effort. Links to register entry R-05.
T-03	Tampering	An actor with write access to the retrieval corpus inserts a new unapproved document, or alters an approved product-disclosure document, changing the fee or eligibility terms the model grounds on, so the assistant quotes tampered terms to applicants with full confidence.	C-4 Retrieval layer — vector store of product terms, rate sheets and disclosures. Boundary TB-3.	Write-path RBAC on the vector store; an allow-list of permitted source-of-record identifiers so that documents outside the approved set cannot be indexed at all; signature verification of approved disclosures at index time; periodic reconciliation of indexed content against the source of record.	CORRECTION — both the inherited worksheet and the draft relied on cryptographic hashing of verified documents. Hashing detects alteration of documents already approved; it does not prevent insertion of a document that was never approved, which is the more likely path. Source allow-listing added as the primary preventive control, with hashing retained as detective. Links to register entry R-01.
T-04	Repudiation	A customer disputes the product terms the assistant stated. The interaction cannot be reconstructed, either because the dispute is raised after the 90-day retention boundary or because logging captured only metadata and an output hash rather than the statement itself.	C-9 Logging, telemetry and audit store. Boundary TB-5, in-tenant processing to logging and analytics.	Retain the full transcript together with the retrieved-context record for each turn, not a hash. Establish the regulatory retention floor and reconcile it against the 90-day ceiling, documenting a formal carve-out where the floor is higher. Bind system prompt version, model identifier and session identifier to every logged turn.	MITIGATED STATUS WITHDRAWN — the inherited worksheet marked Repudiation mitigated on the basis of immutable logging of a model output hash. A hash proves a record has not been altered; it cannot reconstruct what the assistant said, which is what a dispute requires. CROSS-ARTIFACT CONFLICT — the Output Evaluation Checklist requires Context_Docs_Retrieved to be logged for every request; the inherited logging design does not capture it. Links to register entry R-06.

Threat #	STRIDE Category	Threat Description	Affected Component	Mitigation Approach	Human-Review Annotation
T-05	Information Disclosure	Prompt and completion payloads containing government-issued ID numbers and declared annual income are written to application telemetry and analytics sinks outside the controlled data path, because logging is applied at the orchestration layer before data-loss-prevention classification takes effect.	C-9 Logging, telemetry and audit store. Boundary TB-5.	Redaction at the orchestration layer before any log write. DLP classification extended to telemetry and analytics sinks, not primary stores alone. Payload capture disabled in application performance monitoring. Confirmation that Content Safety and platform diagnostic logs do not persist content.	CROSS-ARTIFACT CORRECTION — the Output Evaluation Checklist directs that all names, government IDs and home addresses be stripped from outgoing payloads. Applied literally to this system, that rule would remove the data the assistant exists to collect. The rule must be directional: strip on egress to logs, telemetry, analytics and any third party; retain in-session within the tenant boundary. The checklist requires amendment before it can serve as a release gate. Links to register entry R-05.
T-06	Information Disclosure	Conversation context from one applicant session persists in a shared cache or a mis-scoped session key and is included in the prompt assembled for a different applicant, disclosing one customer's PII to another.	C-2 Session / orchestration service. Boundary TB-2.	Cache partitioning keyed to session identity; per-session isolation of assembled context; automated cross-session leakage tests added to the evaluation suite as a release gate.	MITIGATED STATUS WITHDRAWN — the inherited worksheet mitigated information disclosure with a 'stateless API configuration'. That statement is inconsistent with this system: the tasking requires session data to be retained for up to 90 days, and the Output Evaluation Checklist requires a session identifier bound to every request. The system is not stateless, so the control as written does not exist. Links to register entry R-05.
T-07	Denial of Service	Automated high-volume sessions exhaust the deployment's token throughput during a campaign peak, denying service to legitimate applicants mid-onboarding and inflating consumption cost. Partially completed sessions may also leave applicants in an indeterminate onboarding state.	C-5 Inference endpoint (Azure OpenAI GPT-4o). Boundary TB-2.	Per-session and per-source rate limiting applied at the client channel, before inference is invoked. Maximum token constraints enforced at the orchestration layer. Throughput reservation with burst alerting. Bot detection ahead of the inference call.	MITIGATED STATUS WITHDRAWN — the inherited worksheet marked denial of service mitigated by rate limiting and token constraints with no evidence cited; no test result was supplied, so the assertion is not carried forward. REGISTER GAP RECORDED — the draft correctly identified that no register entry covers availability or consumption cost. The register is fixed at five entries for this submission, so the gap is recorded here and raised for production review rather than silently closed.
T-08	Elevation of Privilege	An adversarial prompt causes the assistant to invoke the account-opening interface with a product tier or limit the applicant is not eligible for, because eligibility is evaluated inside the model rather than enforced by a downstream service the model cannot influence.	C-8 Downstream action interface — identity-verification service and core banking account-opening API. Boundary TB-4.	Eligibility determination moved out of the model into a deterministic service. Allow-list and parameter validation on every downstream call. A signed verification-state token required before account creation. Human approval for any tier exception. Separation verified by adversarial testing against the interface, not asserted.	CORRECTION — the inherited worksheet stated a hardcoded separation between the model layer and workflow fulfilment as though implemented, while marking the row open for review. A control cannot be both asserted and unverified; the separation is treated as unverified until adversarial testing against the account-opening interface produces evidence, and the verification method is now named in the mitigation. This is the highest-consequence threat in the set and crosses a boundary the inherited worksheet did not model. Links to register entry R-07.